CMMC 2.0 Update:

Class Deviation 2025-O0006 & NIST SP 800-53 Rev 5 Adoption

26 February 2026

F. Charlene Watson

Over 20 years of expertise in Cyber Security and Cyber Risk Management, with expertise in NIST RMF, IT Risk Management, FARS, DFARS, UFC, NERC CIP and FERC compliance for Cyber/Risk Regulations and Enterprise Risk Management.

Instrumental in modernizing operation management and driving performance at Pond.

Requested National/International Speaker for OT Cybersecurity Design, Regulations, and Resiliency.

GICSP, CISSP, CISM, CEH, SEC+

charlene.Watson@pondco.com

Lori Jackson

Cybersecurity Consultant, Lead CMMC Certified Assessor and CMMC Certified Professional. Society of American Military Engineers (SAME) Resilience Community of Interest Vice Chair-Cyber

CISSP, LCCA, CCP

DISCLAIMER

The following presentation represents the work and opinion of the presenter for general education purposes and should not be taken as a substitute for professional advice on individual projects or circumstances. While we endeavor to present a comprehensive perspective for today's discussion, it is the responsibility of the viewer to apprise themselves of updates and issues that pertain to their own situation.

Presentation And Analysis

- F. Charlene Watson, GICSP, CISSP, CISM, CRISC, Presenter, Pond & Company, Senior Cybersecurity Operational Technology, SME
  - charlene.watson@pondco.com
- Lori Jackson, President/Owner, White Raven Security
  - lori@whiteravensecurity.com

Table of Contents

01 Background

02 OT, OT Data & CUI

03 Who’s Affected?

04 Acknowledgements

05 Authoritative URLs

BACKGROUND: WHERE WE ARE NOW

What Changed This Fall (Plain English)

- DFARS 252.204-7021 on hold for new awards until the DFARS final rule's effective date (Class Deviation 2025-O0006).
- DFARS final "contract rule" published Sept 10, 2025; effective Nov 10, 2025 (ties CMMC into solicitations/contracts).
- Program rule (32 CFR 170) is already final (Oct 2024) and sets 4-phase rollout.
- Bottom line today: solicitations may not include 7021 until Nov 10; after that, CMMC clauses can appear per phasing.

- Two Rules/Two Purposes
  - 32 CFR Part 170 (Program rule): defines CMMC levels, scoping, and phased implementation.
  - 48 CFR/DFARS (Contract rule): tells KOs how to put CMMC into solicitations and contracts
- Effective Nov 10, 2025: KOs can start including the CMMC provisions when applicable.

What Changed This Fall (Plain English)

- DoD adopts NIST SP 800-53 Rev 5 as of October 1, 2025
- DoD CIO memorandum (Oct 16, 2023) directed adoption of NIST SP 800-53 & CNSSI 1253 Rev 5 across DoD. (Cited in 2025 DoD AI Tailoring Guide.)
- Memo requires selection/implementation of controls per CNSSI 1253 Rev 5 for all DoD systems (not just NSS).
- NIST SP 800-53 Rev 5 and 53B are the current federal control catalog & baselines; NIST issued Release 5.2.0 Aug 2025.
- Careful on dates: Can't substantiate an OSD directive stating, "every component must adopt by Oct 1, 2025." The enforceable document we can cite is the Oct 16, 2023, DoD CIO memo (component adoption/transition followed).
- This presentation links new mandates to OT, A&E, and design contracting impacts.

WHEN OT DATA BECOMES CUI

What Is an “OT/Control System?”

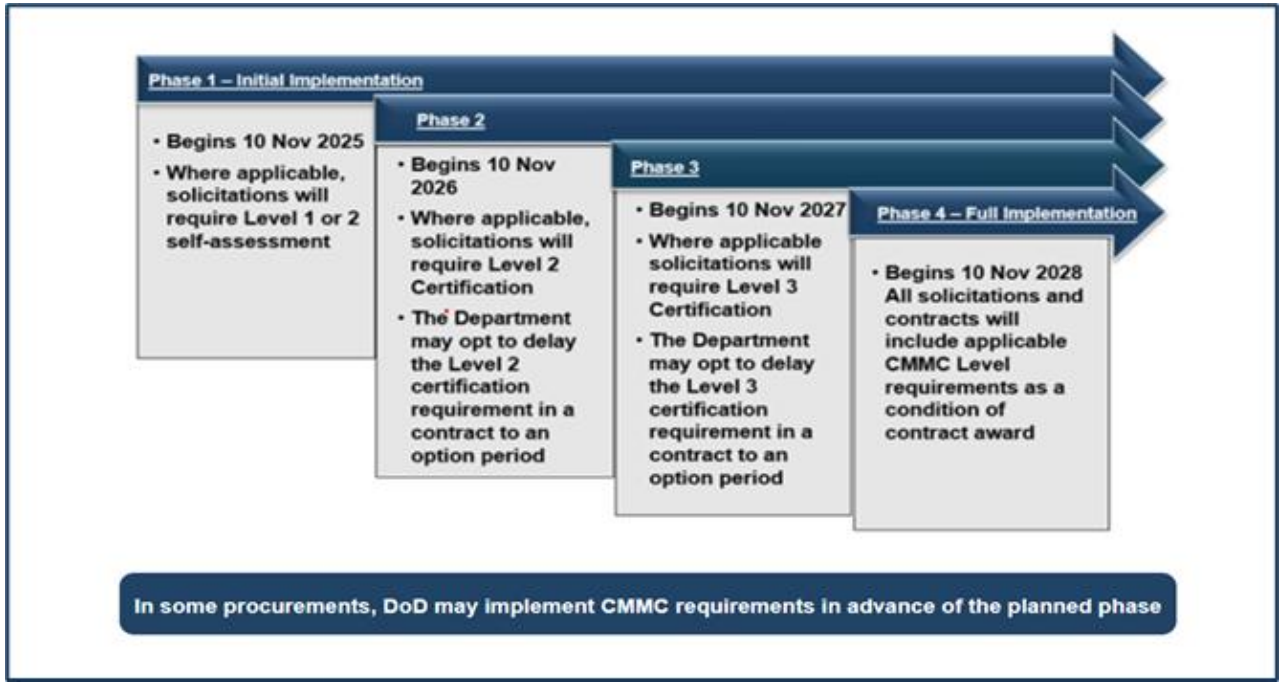
- DAFGM 2024-32-01, Chapter 1, Section 1.1.1.1 states, *“A control system is a collection of technological components that monitor, manage, and/or control the behavior of people, devices, and systems…Typically, they consist of components that can be categorized as inputs, controllers, actuators, sensors, and outputs.”*
- NAVFAC uses the National Institute of Standards and Technology (NIST) definition of OT that is widely used by federal agencies. NIST defines OT as *"programmable systems or devices that interact with the physical environment...through the monitoring and/or control of devices, processes, and events."*
- USACE ER 25-1-113, Appendix D states, *“A control system consists of combinations of control components (e.g., electrical, mechanical, hydraulic, pneumatic) that act together to achieve a specific physical objective in real or near-real time (e.g., moving a tainter gate or starting a pump or generator). This includes protective systems (e.g., generator relays, transformer relays, etc.) and data acquisition systems that support critical infrastructure missions (e.g., dam safety, water data, etc.). A control system can operate as a stand-alone isolated system, as a closed restricted network across multiple geographic locations, or as a connected system…”*

When OT Data Becomes CUI

- *OT Consumption Data* is the real-time data collected from industrial equipment and processes, like sensors and controllers, which is used to monitor and manage physical operations within a facility, such as production levels, energy usage, and machine performance, allowing for optimization and troubleshooting in real-time. (Definition Derived from Tenable ®)
- Department of Defense Considers this "OT Consumption Data" CUI when it:
  - Handles technical or contract-sensitive information designated as CUI
  - Supports defense missions or critical infrastructure with a national security impact
  - Contains configuration or cybersecurity data revealing system vulnerabilities
- It is the nature of the information *provided* by the OT System(s)—not the System(s) itself/themselves is what makes it CUI. (NARA CUI Registry)

OT Systems Handling CUI Require CMMC Level 2

- Requires alignment with NIST SP 800-171 (110 controls) – Rev 2
  - “Why is this important? What about Rev 3? Isn’t that the most current?”
  - DoD "hard coded" Revision 2 into the CMMC requirements.
- <u>Level 2 CMMC Self Assessment or Third-party (C3PAO) assessment?</u>
  - *“What is C3PAO? When is it needed? When should you get it?”*
  - ANSWER: It Depends. Sooner than you think.
- Remember, CMMC rollout is a *phased approach.*



OT Systems Handling CUI Require CMMC Level 2

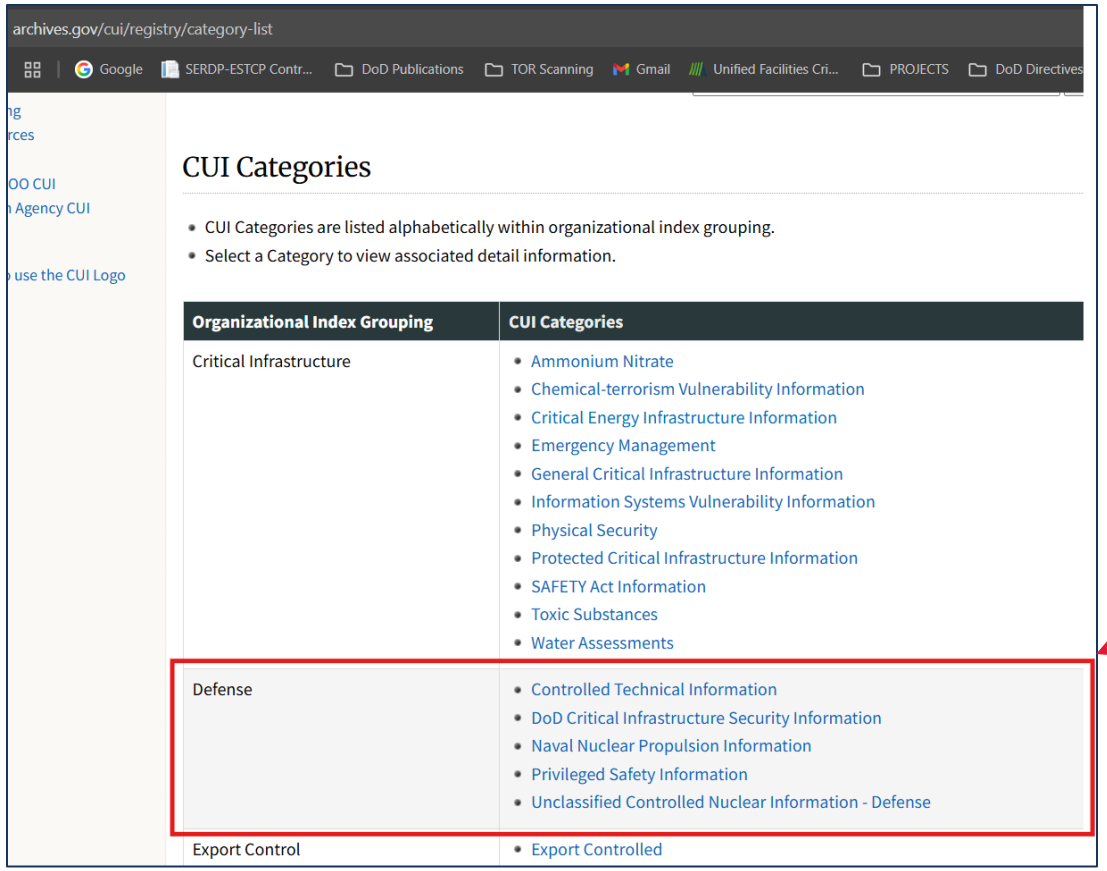
204.7503 Procedures.

(a) *CMMC level.* The contracting officer shall include the CMMC level (see 32 CFR 170.19) required by the program office or requiring activity in the solicitation provision and contract clause prescribed at 204.7504.

(b) *Award.* Contracting officers shall check SPRS and not award a contract, task order, or delivery order to an offeror that does not have a current CMMC status posted in SPRS at the CMMC level (see 32 CFR 170.15 through 170.18) required by the solicitation, or higher, for each CMMC UID provided by the offeror. The CMMC UIDs are applicable to each of the contractor information systems that will process, store, or transmit FCI or CUI and that will be used in performance of the contract.

- Year One→Phased Rollout→Level 2 Self Assesment→May be required by the Department of Defense ***"program office or requiring activity."***
- This is the person who will determine whether the contractor must have the CMMC and at what level.

OT Systems Handling CUI Require CMMC Level 2



archives.gov/cui/registry/category-list

Google | SERDP-ESTCP Contr... | DoD Publications | TOR Scanning | Gmail | Unified Facilities Cri... | PROJECTS | DoD Directives

ng
rces

OO CUI
Agency CUI

use the CUI Logo

CUI Categories

- CUI Categories are listed alphabetically within organizational index grouping.
- Select a Category to view associated detail information.

Organizational Index Grouping	CUI Categories
Critical Infrastructure	• Ammonium Nitrate • Chemical-terrorism Vulnerability Information • Critical Energy Infrastructure Information • Emergency Management • General Critical Infrastructure Information • Information Systems Vulnerability Information • Physical Security • Protected Critical Infrastructure Information • SAFETY Act Information • Toxic Substances • Water Assessments
Defense	• Controlled Technical Information • DoD Critical Infrastructure Security Information • Naval Nuclear Propulsion Information • Privileged Safety Information • Unclassified Controlled Nuclear Information - Defense
Export Control	• Export Controlled

- Year Two→Phased Rollout→Level 2 Third Party Assessment (C3PAO)→May be required by the Department of Defense ***"program office or requiring activity."***
- What is the "CUI Category" of the "requiring activity?"
  - "CUI categories from the Defense Organizational Index group would necessitate a C3PAO assessment, at a minimum."

OT Systems Handling CUI Require CMMC Level 2

archives.gov/cui/registry/category-detail/controlled-technical-info.html

Citizen Archivists · Bookmark/Share · Contact Us

NATIONAL ARCHIVES

Search Archives.gov | Search

ARCH OUR RECORDS | VETERANS' SERVICE RECORDS | EDUCATOR RESOURCES | VISIT US | AMERICA'S FOUNDING DOCUMENTS

trolled Unclassified Information (CUI)

ontrolled Unclassified Information (CUI) > CUI Category: Controlled Technical Information

CONTROLLED UNCLASSIFIED INFORMATION

ry
Change Log
ngs
Dissemination
s
CUI Notices
ng
rces
OO CUI
Agency CUI

CUI Category: Controlled Technical Information

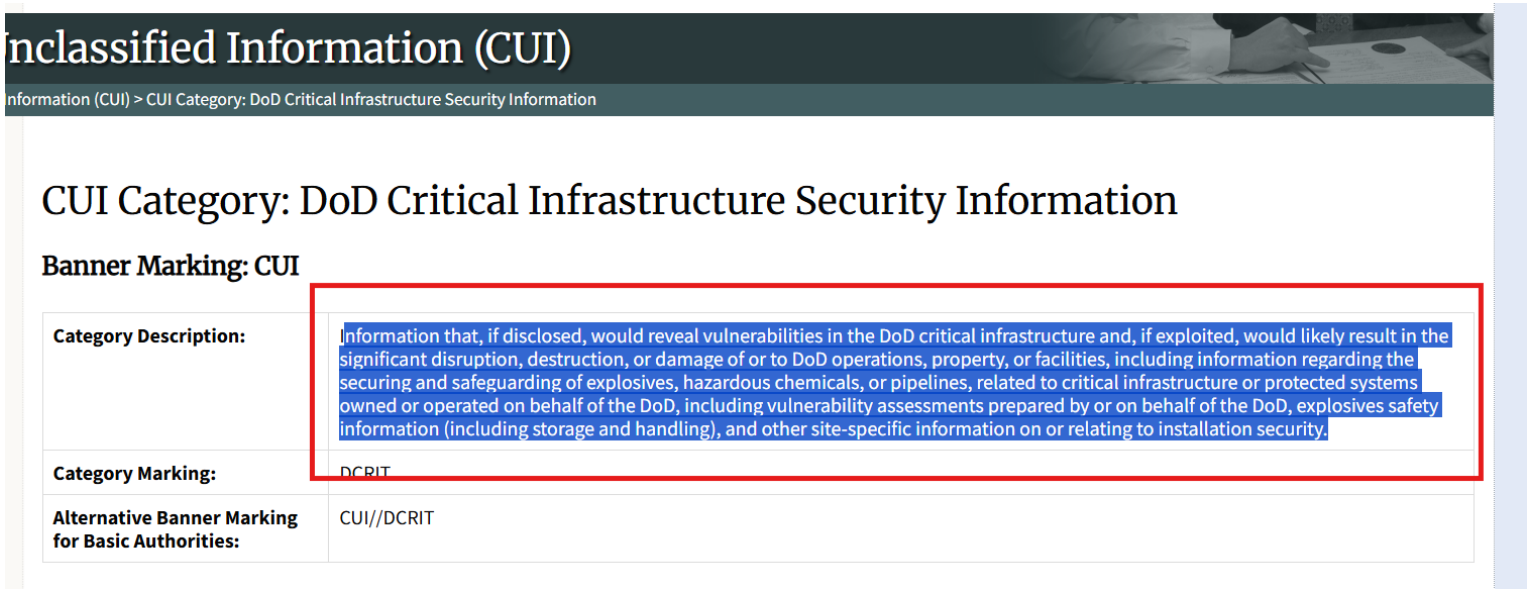
Banner Marking: CUI//SP-CTI

Category Description:	Controlled Technical Information means technical information with military or space application that is subject to controls on the access, use, reproduction, modification, performance, display, release, disclosure, or dissemination. Controlled technical information is to be marked with one of the distribution statements B through F, in accordance with Department of Defense Instruction 5230.24, "Distribution Statements of Technical Documents." The term does not include information that is lawfully publicly available without restrictions. "Technical Information" means technical data or computer software, as those terms are defined in Defense Federal Acquisition Regulation Supplement clause 252.227-7013, "Rights in Technical Data - Noncommercial Items" (48 CFR 252.227-7013). Examples of technical information include research and engineering data, engineering drawings, and associated lists, specifications, standards, process sheets, manuals, technical reports, technical orders, catalog-item identifications, data sets, studies and analyses and related information, and computer software executable code and source code.
Category Marking:	CTI

When we design projects, produce specifications and drawings, edit Div 23, 25, 26, 28 etc. what are we producing????

- "Examples of Controlled Technical Information are…"
  - Research and engineering data
  - Engineering drawings
  - Technical reports
  - Technical data packages
  - Design analysis
  - Specifications
  - Test reports
  - Technical orders
  - Cybersecurity plan
  - IP addresses, nodes, links

OT Systems Handling CUI Require CMMC Level 2



nclassified Information (CUI)

nformation (CUI) > CUI Category: DoD Critical Infrastructure Security Information

CUI Category: DoD Critical Infrastructure Security Information

Banner Marking: CUI

Category Description:	Information that, if disclosed, would reveal vulnerabilities in the DoD critical infrastructure and, if exploited, would likely result in the significant disruption, destruction, or damage of or to DoD operations, property, or facilities, including information regarding the securing and safeguarding of explosives, hazardous chemicals, or pipelines, related to critical infrastructure or protected systems owned or operated on behalf of the DoD, including vulnerability assessments prepared by or on behalf of the DoD, explosives safety information (including storage and handling), and other site-specific information on or relating to installation security.
Category Marking:	DCRIT
Alternative Banner Marking for Basic Authorities:	CUI//DCRIT

- *"Information that, if disclosed, would reveal vulnerabilities in the DoD critical infrastructure and, if exploited, would likely result in the significant disruption, destruction, or damage of or to DoD operations…"*

When we design projects, produce specifications and drawings, edit Div 23, 25, 26, 28 etc. could any of this information ***"reveal vulnerabilities in the DOD critical infrastructure?????"***

OT Systems Handling CUI Require CMMC Level 2

- Requires alignment with NIST SP 800-171 (110 controls) – Rev 2
  - *"Why is this important? What about Rev 3? Isn't that the most current?"*
  - ANSWER: DoD "hard coded" Revision 2 into the CMMC requirements.
- Documentation: Asset inventory + System Security Plan (SSP), security policies and procedures, compliance evidence
  - There is no way to obtain CMMC Level 2 without thoroughly documenting the above listed requirements
- THIS IS WHAT PROTECTS the IT/OT/IoT components within critical facilities – ***"I'm from Missouri….show me!" The C3PAO wants/must see this Documentation.***
- You can have the best documentation but if your ***implementation doesn't match your documentation it will not matter!***

WILL THIS AFFECT A&E DESIGNERS/INSTALLERS?

“Yes/No/Maybe?”

- YES – When your scope processes, stores, or transmits DoD FCI/CUI (e.g., design environments, vendor portals) → expect CMMC Level 1 or 2 self assessments requirements post-Nov 10 in solicitations for year one phased roll out.
- YES - when projects tie into DoD systems requiring RMF packages (FRCS/OT/ICS). Expect Rev-5 control language in specs and RMF documentation deliverables. *CAVEATS, PRIVISOS, PREDICTIONS*
- MAYBE - for purely civil/architectural scope with no CUI handling and no system authorization touchpoints; impact may be limited to supplier/IT hygiene requirements.
- NO - on legacy projects already awarded with no new options/TOs and no CUI; but watch for mods adding CMMC after effective date.

ACKNOWLEDGEMENTS

ACKNOWLEDGEMENTS

- Lori Jackson, White Raven Security – CMMC, US Code Regulatory Analysis Support (lori@whiteravensecurity.com)
- Source Documents: DoD CIO Memo (Oct 16, 2023), Federal Register FR 2025-17359, Class Deviation 2025-O0006, and NIST SP 800-53 Rev 5.
- Prior Research From: ‘Strengthening Cyber Resilience with the CMMC - Essential Updates and Strategies for the Defense Industrial Base’ (March 2025, Jackson); ‘CMMC 2.0 Requirements for OT Systems’ (March 2025, Watson)

AUTHORITATIVE URLs

1. Class Deviation 2025-O0006 – DFARS 252.204-7021 on hold until DFARS final rule effective date.
   https://www.acq.osd.mil/dpap/policy/policyvault/Class-Deviation-2025-O0006.pdf

2. DFARS Final Rule (FR 2025-17359) – Cybersecurity Maturity Model Certification (CMMC) 2.0.
   Federal Register: https://www.federalregister.gov/d/2025-17359

3. 32 CFR Part 170 – Cybersecurity Maturity Model Certification Program Rule.
   eCFR: https://www.ecfr.gov/current/title-32/subtitle-A/chapter-I/subchapter-I/part-170

4. DoD CIO Memorandum (Oct 16, 2023) – Adoption of NIST SP 800-53 Rev 5 and CNSSI 1253 Rev 5.
   https://dodcio.defense.gov/Portals/0/Documents/Cyber/Memo_NIST_SP_800-53_Rev5_Adoption.pdf

5. NIST SP 800-53 Revision 5 (Security and Privacy Controls for Information Systems and Organizations).
   https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final

6. NIST SP 800-171 Revision 2 – Protecting Controlled Unclassified Information in Nonfederal Systems.
   https://csrc.nist.gov/publications/detail/sp/800-171/rev-2/final

7. Air Force Guidance Memorandum DAFGM 2024-32-01 – Cyber Resiliency for Control Systems.
   https://www.saf-cn.af.mil/Portals/71/documents/DAFGM2024-32-01.pdf

8. OPNAVINST 5239.1E – Navy Cybersecurity Program (CYBERSAFE Integration).
   https://www.secnav.navy.mil/doni/OPNAVINST/05239.1E.pdf

9. Army Engineering & Support Center – Cybersecurity Systems Mandatory Center of Expertise (CSC-MCX).
   https://www.hnc.usace.army.mil/Missions/Cybersecurity-MCX/

10. SANS Institute (2025). State of OT/ICS Cybersecurity Survey.
    https://www.sans.org/white-papers/state-of-ot-ics-cybersecurity-2025/

POND

We earn the trust that sets us apart.

White Raven
SECURITY